

Guía paso a paso para detectar vulnerabilidad XSS mediante fuzzing con Burp Suite

Paso 1 abre Burp Suite y asegúrate de que esté corriendo correctamente, preferiblemente con la versión Community Edition. No es necesario iniciar ningún proyecto aún, solo confirmar que la interfaz esté activa.

Paso 2 abre tu navegador (por ejemplo, Firefox) y configura manualmente el proxy para que todo el tráfico se enrute a través de 127.0.0.1 con puerto 8080. Esto se realiza desde las opciones de red del navegador, desactivando la detección automática y configurando el proxy manualmente.

Paso 3 accede al sitio de pruebas desde tu navegador usando la URL <http://testphp.vulnweb.com/> Este es un sitio diseñado para prácticas de seguridad, con un formulario vulnerable en su interfaz.

Paso 4 en la interfaz del sitio, localiza el formulario de búsqueda. Escribe cualquier palabra clave como por ejemplo "test" en el campo de entrada y presiona el botón de búsqueda para enviar la solicitud al servidor.

Paso 5 asegúrate de que Burp Suite esté con la opción de interceptación activada (Proxy > Intercept > Intercept is on). En este punto la solicitud que acabas de generar al presionar "buscar" debería aparecer en la pestaña Intercept.

Paso 6 verifica que la solicitud capturada contiene el parámetro arname en la URL o en el cuerpo, dependiendo del método utilizado. Este parámetro es el objetivo principal para la prueba de XSS.

Paso 7 haz clic derecho sobre la solicitud interceptada y selecciona la opción "Send to Intruder". Esto enviará la solicitud al módulo Intruder de Burp Suite para su configuración y ejecución.

Paso 8 dirígete a la pestaña Intruder y dentro de ella selecciona "Positions". En esta vista se mostrarán todos los parámetros detectados por Burp. Borra todas las marcas de posición automáticas y selecciona únicamente el valor del parámetro arname. Luego, haz clic en "Add §" para delimitarlo como objetivo del ataque.

Paso 9 selecciona la pestaña Payloads. Allí elige el tipo de ataque "Sniper" (por defecto) y en el campo de payloads manualmente ingresa una lista de vectores XSS comunes como `<script>alert(1)</script>`, `"><img src=x onerror=alert(1)>`, `<svg/onload=alert('XSS')>`, `'"><svg onload=confirm(1)>`. Asegúrate de tener al menos 4 o 5 cargas distintas.

Paso 10 haz clic en el botón “Start Attack”. La herramienta comenzará a enviar solicitudes una por una, reemplazando el valor del parámetro arname con cada payload configurado.

Paso 11 una vez iniciados los ataques, monitorea la tabla de resultados. Observa columnas como “Status”, “Length” y “Response” para identificar variaciones. Las respuestas que reflejen un cambio significativo en la longitud o en el contenido podrían indicar una ejecución del payload.

Paso 12 selecciona una respuesta sospechosa en la tabla de resultados. Ve a la pestaña “Response” y luego selecciona la vista “Render”. En esta vista podrás ver si alguno de los scripts inyectados se ha ejecutado o al menos se ha reflejado sin ser filtrado, lo cual es evidencia de vulnerabilidad.

Paso 13 si encuentras una respuesta donde el contenido inyectado se muestra tal cual sin ser codificado, esto indica que el sistema es vulnerable a ataques de tipo XSS reflejado. Una alerta que se dispara en el navegador también es una señal clara de éxito.

Paso 14 documenta la configuración exacta utilizada en Intruder incluyendo los delimitadores \$, el payload utilizado, el tipo de ataque y las respuestas detectadas como vulnerables. Se espera una captura de pantalla de Intruder configurado, una captura del resultado exitoso, una breve explicación técnica del porqué del fallo de seguridad y sugerencias de mitigación como codificación de salida y validación del lado servidor.